

Zero Trust Architecture, Defense in Depth, and Layered Defense

A Case Study in the Healthcare Industry

Simulated Cyberattack: Ransomware

Student ID: 8876149 | CSIT302 (SP226) Cybersecurity | University of Wollongong

1. Summary

Hackers target hospitals and healthcare facilities more frequently than any other sector. When you consider it, this is hardly shocking. They have extremely sensitive patient information, many of their gadgets are outdated and difficult to upgrade, and their systems are essentially unable to go offline without endangering lives. Three cybersecurity tactics Zero Trust Architecture (ZTA), Defense in Depth (DiD), and Layered Defense are the main topics of this essay. I'll examine each one's functions and trade-offs before talking about how they may cooperate to protect a hospital against a ransomware assault. I selected the healthcare sector because I believe it provides the most accurate illustration of why cybersecurity is not only a technological problem but also an operational and human one.

2. Exploring the Three Strategies

2.1 Zero Trust Architecture (ZTA)

The basic idea of Zero Trust is simple: do not trust anyone, even if they are already inside the network. The traditional security system is like a castle. Once you get past the walls, you can move around freely. ZTA rejects this completely. Every user and every device have to prove who they are before accessing anything, every single time (NIST, 2020). Access is also restricted to only what is needed. A nurse should not be able to open financial records just because she is on the hospital network.

To make this work, ZTA relies on things like multi-factor authentication (MFA), identity and access management (IAM), and breaking the network into smaller isolated segments (micro-segmentation). These restrictions work together to make sure that even if an attacker gets in somewhere, they cannot just move around freely.

Advantages

The important benefit is containment. The attacker is trapped if an attack occurs. They cannot access systems they do not have permission for, so the damage stays limited. IBM (2023) reported that hospitals using Zero Trust saved roughly USD 1.76 million per attack compared to those without it. ZTA also helps with compliance. HIPAA requires hospitals to control who sees patient data, and ZTA is built for exactly that. It is also flexible enough to work with remote staff and cloud systems, which most hospitals now rely on.

Trade-offs

The problem is implementation. Hospitals are full of old medical equipment such as CT scanners, infusion pumps, and monitoring systems that were never designed with modern authentication in mind. Installing a new ZTA around all of this is expensive and time consuming. There is also the human factor. Doctors and nurses are busy individuals. If logging in becomes too complicated or slow, they will find shortcuts, which ruins the whole point. Gartner (2022) indicated that fewer than 10% of businesses had fully operational ZTA installations as of 2022, and staff resistance was one of the key causes.

2.2 Defense in Depth (DiD)

Defense in Depth is fundamentally the principle that you should never rely on just one security control. Something else should be able to solve the issue if one fails. It is described as layering security controls across people, technology, and processes by the SANS Institute (2019). In a medical facility, this could feature physical locks on server rooms, firewalls at the network edge, antivirus software on every machine, email filters to prevent phishing, and frequent staff training all operating continuously. While neither of these is effective on its own, when combined, they significantly reduce the probability of an attack succeeding.

A good way to understand DiD is to think about what happens with a phishing email. The email filter might miss it. But then the endpoint security tool might catch the malware when it tries to run. If the malware still runs, network monitoring might detect it sending data out. Each layer gives another chance to stop the attack.

Advantages

For healthcare, the redundancy that DiD provides is extremely valuable. Hospital systems need to stay up. If the main firewall fails, there needs to be something else behind it. DiD also handles a problem that ZTA struggles with older devices. A legacy medical equipment can be protected from outside threats by network-level restrictions even if it cannot be upgraded. Additionally, DiD works well with compliance standards like ISO 27001 and NIST CSF (Cisco, 2021), which is beneficial for audits.

Trade-offs

Running multiple security tools creates its own problems. Different systems produce different alerts, and security teams can quickly get overwhelmed. This is called alert fatigue, and it is a real issue in hospitals where IT teams are often small. Managing and paying for all these tools is also expensive, which makes full DiD implementation unrealistic for smaller healthcare facilities.

2.3 Layered Defense

Layered Defense is sometimes confused with DiD, but they are different. DiD is about having many independent controls running at once. The goal of layered defense is to place such restrictions in a purposeful order so that an attacker must break each one sequentially. According to Palo Alto Networks (2022), every layer is created with the presumption that the layer before it may have already failed. Perimeter (firewalls, DMZ), network (IDS/IPS, VLANs), application (web application firewalls), endpoint (antivirus, patching), and data (encryption, access restrictions) are typical levels that run from outer to inner.

When an attacker trying to access the patient's database of a hospital. First, they hit the network firewall. If they get past that, there will be a web application firewall. Then they need valid login credentials. Then the database itself is encrypted. Each step slows them down and gives defenders more time to notice something is wrong.

Advantages

The way Layered Defense is set up makes it really easy to manage and explain to people. When something goes wrong the security teams can see away which part of Layered Defense is being attacked. This means they can react a lot faster. It is also a lot easier to show hospital management or regulators what is going on because each part of Layered Defense has a job that everyone understands. This makes things really clear. Sometimes Defense, in Depth or DiD can be a bit confusing. Layered Defense does a better job of making things simple and easy to understand.

Trade-offs

The main weakness is that Layered Defense tends to assume attackers come from outside. Many of the external security levels are already bypassed if someone is already inside, such as an employee with internal access or a hacked employee account. A skilled attacker who has researched the design may also figure out how to get past each tier without setting off alarms. Therefore, even if the structure is useful, it may create false believe of security, if teams neglect internal dangers.

3. Unified Defense Against a Ransomware Attack in Healthcare

3.1 The Simulated Attack Scenario

Ransomware is a problem for hospitals right now. For example Universal Health Services, one of the hospital networks in the United States was attacked by ransomware in 2020. This ransomware attack shut down all of the systems at Universal Health Services for weeks. Something similar happened in 2021 at the Irish Health Service Executive or HSE for short. It affected patient treatment all over the country. The scenario below is modeled on these real events.

Stage 1: Initial Access. A hospital administrator receives a phishing email with a Word document attached. The document contains a hidden macro. When the admin opens the document, the macro installs an invisible Remote Access Trojan (RAT) on the administrator's computer.

Stage 2: Lateral Movement. The RAT works quietly in the background for days. It collects the administrators login details. The attacker then uses these details to get into systems, on the same network. They try to find the server that stores Electronic Health Records or EHRs. The attacker searches for the EHR server.

Stage 3: Payload Deployment. When the attacker gets to the server they use ransomware to lock up every single patient file. The clinical systems like the pharmacy and the radiology system go down. Then a message pops up that says they want money in exchange for the key to unlock the files. This ransom message is pretty straightforward they just want cash to give back the decryption key, for the files.

3.2 How the Three Strategies Work Together

None of these techniques work alone. When used together they cover all parts of the attack. Here is how each one helps:

Stage 1: Initial Access. Layered Defense's email security layer should catch the phishing email and either block it or quarantine the attachment before the administrator even sees it. If somehow the email still gets delivered, DiD's endpoint protection tools should detect when the macro tries to execute and block it. ZTA's continuous monitoring adds another layer of detection. If the RAT does install and tries to contact an external server, that unexpected outbound connection should trigger an alert.

Stage 2: Lateral Movement. This is really where ZTA shines. Because every access request inside the network requires fresh verification, the stolen administrator credentials alone are not enough to open the EHR server. That account simply does not have permission to be there. The micro-segmentation also means the attacker is trapped in one network zone. Meanwhile, DiD's IDS/IPS tools should notice the unusual internal traffic patterns and alert the security team.

Stage 3: Payload Deployment. DiDs data layer makes sure that all patient records are locked away and cannot be read even if someone tries to get into the EHR server. The hospital also makes sure to keep copies of all the records on systems that are not connected to the internet so if something bad happens and files get encrypted by ransomware the hospital can still keep working with the patient records. DiDs data layer is really important, for keeping records safe.

Each approach deals with certain aspects of the issue that the others do not effectively address. Layered Defense blocks the entry point. ZTA stops the spread. DiD handles recovery and redundancy. Together they are far stronger than any one approach alone.

3.3 My Thoughts

Ransomware attacks still happen in hospitals because of weaknesses not because they don't have security. ZTA alone won't help if old devices can't support logins. A DiD approach alone won't help if the security team is too small to handle alerts. Layered Defense alone won't help when an attacker is already inside using a real account.

What I find interesting is how each strategy's weakness is covered by another. ZTA's access controls fix the internal movement problem that Layered Defense misses. DiD's backups and redundancy address the recovery gap that ZTA doesn't focus on. Layered Defense provides the structure that stops DiD from becoming a mess of tools. This is not about having three strategies. It is about using them to fill each other's gaps.

I also think people underestimate the side of cybersecurity, in healthcare. No amount of technology helps if a doctor clicks on a phishing link because they were never trained to spot one. Staff awareness and technical controls are equally important. Hospitals should apply these steps gradually starting with the systems that pose the danger. They should not try to change everything at and risk disrupting patient care.

References

- Cisco (2021) What is Defense in Depth? Cisco Security. Available at: <https://www.cisco.com/c/en/us/products/security/what-is-defense-in-depth.html> [Accessed 16 May 2026].
- Gartner (2022) Zero Trust Network Access Market Guide. Gartner Research. Available at: <https://www.gartner.com/en/documents/4010078> [Accessed 16 May 2026].
- IBM Security (2023) Cost of a Data Breach Report 2023. IBM Corporation. Available at: <https://www.ibm.com/reports/data-breach> [Accessed 16 May 2026].
- National Institute of Standards and Technology (NIST) (2020) Zero Trust Architecture (NIST Special Publication 800-207). U.S. Department of Commerce. Available at: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf> [Accessed 16 May 2026].
- Palo Alto Networks (2022) What is a Layered Security Approach? Palo Alto Networks. Available at: <https://www.paloaltonetworks.com/cyberpedia/what-is-defense-in-depth> [Accessed 16 May 2026].
- SANS Institute (2019) Defense in Depth: A Practical Strategy for Achieving Information Assurance. SANS Reading Room. Available at: <https://www.sans.org/white-papers/525/> [Accessed 16 May 2026].
- Health and Human Services (HHS) (2023) Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients. U.S. Department of Health and Human Services. Available at: <https://www.hhs.gov/sites/default/files/HICP-Main-508.pdf> [Accessed 16 May 2026].